

Lab 3: Architecture Selection and Justification

Name: Nakka Gopya **SRN:** PES1UG24AM107 **Section:** B

System: Patient Health Record Consent Management System (Problem Statement #13)

Architecture Selection

We chose **Layered Architecture** for the Patient Health Record Consent Management System.

Architectural Choice

The system is organised into three horizontal layers. The **Presentation Layer** holds the User Interface. The **Business Layer** holds the Authentication Service, Consent Manager, Record Access Service, Notification Service and Audit Trail Service. The **Data Layer** holds the Database Component. Components talk through provided and required interfaces (IAuthentication, IConsentManagement, IRecordAccess, IConsentCheck, INotification, IAuditLog, IDataAccess), and each layer only calls the layer directly below it.

Two Reasons

1. **Single enforcement point for consent rules.** Time-bound grants, revocation and automatic expiry (FR-001, FR-002) must be applied on every record access. In a layered design all of this logic sits in one business layer: the Record Access Service must call the Consent Manager (IConsentCheck) before any record is returned, so the UI and database cannot bypass consent.
2. **Strong consistency with low operational complexity.** The scope is one cohesive domain (5 functional and 2 non-functional requirements, 3 actor types). A revoked consent must stop access within 5 seconds, and every consent event must be recorded in the audit trail (NFR-001). A single deployable system with one transactional database keeps consent state and audit entries consistent. Microservices would add network hops, distributed-data consistency problems and deployment overhead that this system does not need.

Security Advantage

Layer isolation limits the attack surface. Only the Data Layer touches the database, and the User Interface has no direct data access. Every record read passes through the Record Access Service, which checks consent and writes to the append-only Audit Trail Service before returning data. Records are encrypted with AES-256 at rest and all calls use TLS 1.2+ in transit (NFR-002). The audit store can be given an insert-only database account, which supports the tamper-evident log required by NFR-001.

Performance Benefit

Calls between layers are in-process, so there are no network hops between services. The Business Layer can also cache consent decisions and expiry timestamps with a short time-to-live, invalidating the cache on revoke. This keeps access checks fast under peak load while still meeting the 5-second revoke target (FR-002). Database indexes on timestamps support the 3-second audit-trail date filtering (FR-005).

Trade-off Acknowledged

Layered architecture is harder to scale piece by piece and has tighter coupling between layers. We accept this because the whole stack can be scaled horizontally behind a load balancer, and the interfaces keep components replaceable.